

****14.04.2022****

****Final Decision Regarding the Fine of 100,000 Euros****

By Civil Decision No. 9 of 13.04.2022, final, the Cluj Court of Appeal confirmed the fine in the amount of 100,000 euros imposed by the Supervisory Authority of Banca Transilvania for the violation of art. 32 para. (1) and (2) in conjunction with art. 5 para. (1) letter f) of the General Regulation on Data Protection.

Furthermore, the same favorable solution for the Supervisory Authority was pronounced at first instance, by Civil Sentence No. 1309 of 06 May 2021 of the Cluj Tribunal, fully upheld by the appellate court, noting that "the lawsuit filed by the defendant Banca Transilvania SA against the defendant National Authority for the Supervision of Personal Data Processing is unfounded and will be dismissed, the contravention report No. 23409 drawn up by the defendant on 26.11.2020 being maintained as fully legal and well-founded."

To reach this conclusion, "the Tribunal emphasizes that the Regulation introduced a much higher level of accountability for the data operator compared to Directive 95/46/EC on data protection, and articles 25 and 32 of the Regulation stipulate that operators 'take into account the current state of technology, the costs of implementation, and the nature, scope, context, purposes of processing, as well as the risks with varying degrees of probability and severity for the rights and freedoms of natural persons that processing presents.'"

Moreover, the court correctly noted the following aspects:

"In this case, to prove its diligent conduct regarding the training of personnel in the field of personal data protection, the claimant submitted a series of internal regulations as well as proof of organizing courses on this topic; however, it is important to emphasize that the actual participation of personnel in these courses was not proven, nor was there any effective application of a means of verifying the acquisition of this knowledge and information.

Moreover, the aspects invoked by the claimant in the sense that it had taken appropriate measures to implement the provisions of the Regulation are contradicted by the facts established by the contravention report, which were not contested, attesting to the intentional, unauthorized disclosure by individuals under the authority of the Bank of a significant [set] of personal data

(some of which are classified as extremely sensitive) to a very large number of persons. The nonchalance with which the claimant's employees acted, transmitting the personal data of the bank's client from one to another and subsequently to third parties via the Whatsapp application, attests not only to a lack of knowledge of the working procedures regarding the processing of personal data but, more importantly (and more seriously), to their inability to identify and qualify the data they accessed as personal data, which indicates a severe lack of effective training. Thus, although the claimant submitted copies of various internal procedures to the file, it did not prove, on the one hand, the effective training of the three employees who caused the security incident, and on the other hand, that it applied the control and evaluation mechanisms developed to ensure that its employees had acquired the aforementioned internal regulations.

Therefore, the documents presented by the claimant, in proof of the implementation of appropriate organizational technical measures, are not capable of proving the assurance of an adequate level of security regarding the ability to ensure confidentiality and the periodic testing, evaluation, and assessment of the effectiveness of the technical and organizational measures to guarantee the security of processing."

Regarding the consequences of the violation, the Cluj Tribunal noted that "these were correctly qualified by the defendant as serious in relation to the quantity of personal data disseminated by the Bank's employees, their sensitive nature, the manner of dissemination (via the internet, the email containing the Bank's client data circulating intensively in the public space, summarized information being taken up even by blogs, TV channels, and news sites), the extremely large number of persons who gained access to the Bank's client data for an indeterminate period of time, as a result of the transmission of information by various means, all these aspects being capable of providing a correct picture regarding the scope and seriousness of the consequences of the security incident.

The claimant also acknowledged, in relation to the manner of transmitting personal data, that the measures taken to limit the consequences of the security breach were not "feasible," the extent of their dissemination in the public space being clearly out of control.

The defendant appropriately utilized the criteria

provided in art. 83 para. (2) letters c)-k), the evidence of the thorough examination of these criteria being precisely the establishment of a fine in an amount much lower than the maximum allowed for the act committed by the claimant.

Moreover, the report includes in detail the analysis carried out by the defendant regarding each of the criteria established by art. 83 para. (2) for the individualization of the sanction."

In conclusion, the first-instance court correctly concluded that:

"For all the factual and legal considerations set forth above, the tribunal will conclude that the fine in the amount of 100,000 euros is legal, 'effective, proportional, and dissuasive' and was established taking into account the nature, gravity and consequences of the violation, as well as all other criteria provided by the Regulation, criteria that have been analyzed by the defendant in a coherent and objective manner.

In this context, we specify that, through the press release that can be consulted at the address https://www.dataprotection.ro/?page=Comunicat_17_12_2020, the National Supervisory Authority has made public relevant information regarding the investigation concluded at the operator Banca Transilvania SA, following which a violation of the provisions of art. 32 para. (1) and (2) in conjunction with art. 5 para. (1) lit. f) of the General Data Protection Regulation was found.

At the same time, we emphasize that in other similar cases of violation by operators in the financial institutions sector of the GDPR provisions regarding data processing principles and the measures to ensure their security, through final court rulings, the courts have upheld the reports through which fines were imposed, as follows:

- The Bucharest Court of Appeal confirmed the fines imposed on the operator Vreau Credit in the total amount of 95,024 lei (equivalent to 20,000 euros) for the violation of art. 32 and 33 of the GDPR;
- The Bucharest Court of Appeal confirmed the fines imposed on the operator Hora Credit in the total amount of 66,901.8 lei (equivalent to 14,000 EUR), for the violation of art. 5 para. (1) lit. d) and f), art. 5 para. (2), art. 25, art. 32 and art. 33 para. (1) of the GDPR.

Legal and Communication Department
A.N.S.P.D.C.P.